User Prompts in AI-Assisted Security

LESSON 1.2.10

COMPTIA SECAI+

Learn how to craft effective user prompts that direct large language models toward precise, actionable security analysis — the essential skill that separates useful AI output from noisy guesswork.

What Is a User Prompt?

The Definition

A user prompt is the actual instruction or question you send to a large language model (LLM). It operates **within the guardrails set by the system prompt** and tells the model exactly what analytical task to perform on a given piece of data.

Think of the system prompt as the rulebook and the user prompt as the play call and both are necessary for a successful result.

The "Steering Wheel" Analogy

If the system prompt is the car's chassis and engine, the user prompt is the **steering wheel**. It directs the model toward a specific analytic goal such as malware classification, risk scoring, log triage, or threat attribution and at the moment you need it.

Without a well-formed user prompt, even the most capable model will produce generic, unfocused output.

The Three Elements of an Effective Prompt

Every high-quality security prompt is built from three core components. Missing any one of them degrades the model's output.

1

Context

The evidence or data the model will inspect. This could be a raw log entry, a decoded script, a packet capture summary, or a suspicious file hash. **The richer and more specific the context, the better the analysis.**

2

Perspective

The analytical lens or persona you assign to the model. For example: *"You are a malware analyst"* or *"You are a threat intelligence researcher."* Perspective shapes how the model frames its reasoning.

3

Output Shape

The exact format the response must follow. Define it explicitly — JSON with specific keys, a numbered list, a Markdown table. **Structured output enables direct ingestion into SIEM/SOAR pipelines.**

Practical Example: Malware Analysis Prompt

See how the three elements come together in a real-world security scenario involving a suspicious PowerShell script.

🔍 Input (Context)

A decoded PowerShell script that downloads an executable from an unfamiliar external IP address — flagged by an endpoint detection tool.

💬 The Prompt

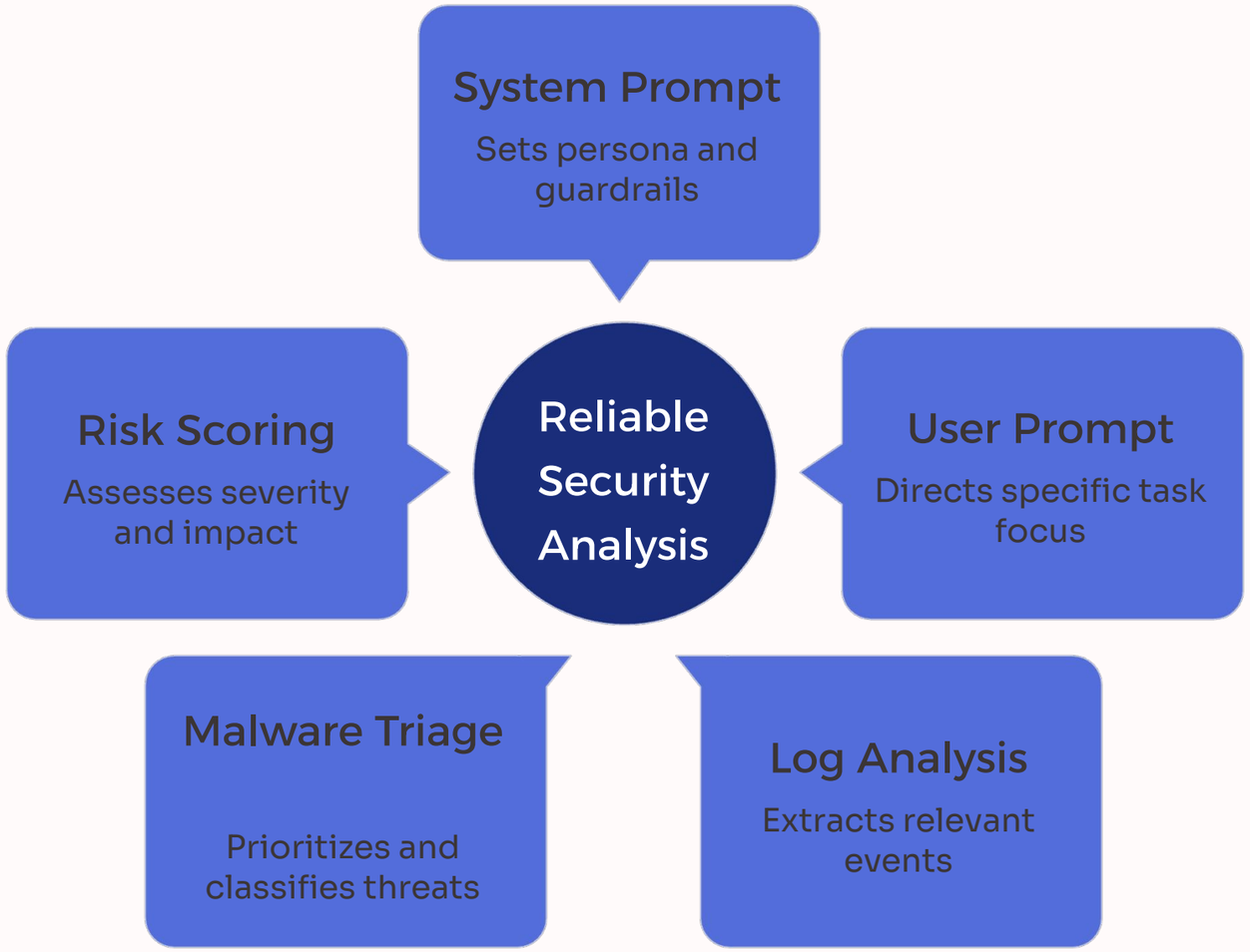
"You are a malware analyst. Determine which phase of the attack chain this command represents, rate its risk on a scale of 1–10, and suggest two containment actions. Return results as JSON with keys: `risk_score` *and* `attack_phase`*."*

✅ Result

Structured, actionable JSON output — immediately ready for ingestion into a SIEM or SOAR platform with no manual reformatting required.

Combining System Role + User Prompt

Neither prompt type works in isolation. Together, they create a reliable, repeatable analysis engine for security workflows.



System Prompt Role

Defines the **outer guardrails** — the model's persona, behavioral constraints, and default output format. It remains constant across many user interactions and ensures the model always behaves as a security professional.

User Prompt Role

Provides the **specific task** for each interaction — the piece of evidence to analyze, the question to answer, and any additional format requirements. It adapts with every new piece of data you feed the model.

Handling Sensitive Data in Prompts

⚠️ **Critical Risk:** Data submitted to public AI models may be logged, retained, or used for model training. Never send real client IPs, internal hostnames, or proprietary code to a public LLM without sanitization.

→ The Problem

Security prompts frequently contain sensitive artifacts: client IP addresses, internal hostnames, proprietary source code, and personally identifiable information. Each of these poses a data exposure risk.

→ The Solution: Placeholder Substitution

Before submitting a prompt to any public model, **replace identifying details with realistic placeholders**. Examples: `192.168.10.25` → `192.168.x.x` | Private S3 bucket → `bucket_placeholder`. The model still understands the structure; the sensitive value is never exposed.

Tokenized Replacement Technique

Tokenized replacement is the professional standard for sanitizing prompts without degrading analysis quality.

How It Works

Replace sensitive values with **consistent, format-preserving tokens** that mimic the structure of genuine data. The token uses the same format as the real value — same character count, same delimiters but contains no confidential information.
Because the structural relationships are preserved, the model can still reason accurately about the data's meaning and context.

Real Value	Token
`10.0.1.45`	`10.x.x.x`

Why It Matters

Preserves Reasoning Accuracy

The model retains the structural context it needs such as the IP format, file path structure, or hostname pattern to produce accurate analysis.

Prevents Data Leakage

No confidential value ever reaches the public AI service. Compliance with data handling policies is maintained.

Best Practices for User Prompts

Apply these four principles consistently to produce high-quality, production-ready AI-assisted security analysis.

Be Specific

Vague prompts produce vague output. State exactly what you want the model to analyze, what question to answer, and what decision you need to make. Specificity is the single biggest driver of output quality.

Define Output Format

Always specify the exact format — JSON with named keys, a numbered list, a Markdown table. Defined output enables downstream automation and eliminates manual reformatting in SIEM/SOAR workflows.

Scrub Sensitive Data

Apply tokenized replacement before submitting any prompt containing real IPs, hostnames, credentials, or proprietary code to a public model. Make sanitization a mandatory pre-submission step.

Test Before Production

Validate your prompt with anonymized sample data before deploying it in live workflows. A prompt that works on test data will behave predictably on real incidents.

Key Takeaways

LESSON 1.2.10 SUMMARY

User Prompts Are the Steering Wheel

They direct the model toward a specific analytic goal within the guardrails established by the system prompt. Both elements are required for consistent, reliable output.

Three Elements = Better Output

Every effective security prompt includes **context** (the data), **perspective** (the analytical role), and **output shape** (the required format). Missing any one element degrades the result.

Data Privacy Is Non-Negotiable

Always sanitize prompts using tokenized replacement before submitting to public AI services. Preserve structure; eliminate sensitive values. This protects clients, organizations, and your own compliance posture.

Specificity Drives Quality

Define the output format explicitly, test with sample data, and refine iteratively. Prompt engineering is a skill — the more precise your inputs, the more actionable your AI-assisted analysis.